

NYC / AI AGENT SECURITY SUMMIT

# Your Agent Escaped Without Escaping the Sandbox

Yossi Eliaz

Principal Engineer and Head of DevRel at Incredibuild.com

October 21, 2026

Nobody climbed the wall

# Four non-escape escapes.

Badge Chair Mailbox Rulebook

The process stays put. A decision you care about still moves.

# 01 / It had dad's badge

GET /projects/other/private

runner token        200

task token         403

its own input       200

We hung the key around its neck. Mint a tiny one.

Recorded Linux isolation run + factory

## 02 / It sat in the next job's chair

```
worker writes /shared/next-job.json
```

```
writable bind    host file changes  
read-only bind  write denied  
/output         still works
```

The mount worked. That was the bug.

Recorded Linux isolation run + factory

## 03 / The allowed door

same host, wrong mailbox

|               |                          |
|---------------|--------------------------|
| team/reports  | intended                 |
| other/uploads | gets the private fixture |

Don't let it address the envelope.

Recorded Linux isolation run + factory

## 04 / The test said yes

|               |                |
|---------------|----------------|
| checker.py    | hash unchanged |
| expected.json | worker-written |
| CI / merge    | PASS           |

|                        |              |
|------------------------|--------------|
| GET /admin (no cookie) | 401 required |
| shipped                | 200          |

We protected the referee. The player wrote the rulebook.

Recorded Linux isolation run + factory

# Four locks

## Story

## Who can actually say no

Dad's badge

Tiny, short-lived task token

Next job's chair

Read this, write that

Allowed door

Broker + no direct route

The test said yes

Freeze bytes. Grade off the worker.

A diary can still say the vault is fine. Keep a copy it cannot rewrite.

Recorded Linux isolation run + factory

# Steal these four

## Ask Monday

Whose identity?

Which files, including tomorrow?

Which mailbox, which letter?

Who says /admin is locked?

Name a no outside the worker. Then prove the real job still works.

## If the answer is the box...

You handed dad's badge over

The next job's chair is still there

The allowed host was the wrong question

That's a diary, not a verifier

THE PROCESS NEVER LEFT

# Who gave this process the authority?

[github.com/zozo123/nyc-talk](https://github.com/zozo123/nyc-talk)

Then go enjoy New York.

## Appendix / Steal the repo

```
make factory      # freeze, judge, gate  
make demo         # Linux isolation lab  
make deck         # this PDF
```

29 lab checks passed, 6 factory checks passed.

## Appendix / What we are not claiming

This is a friendly lab, not a vendor 0-day.

Deterministic scripts. Synthetic /admin. Finite cases.

Twenty-nine checks are not twenty-nine CVEs.

## Appendix / If someone wants homework

[github.com/zozo123/nyc-talk](https://github.com/zozo123/nyc-talk)

Script, slides, recorded results

AI Agent Security Summit, NYC

You are here